



**OFICINA DE SOLUÇÕES
PROFISSIONAIS**

ORIENTAÇÕES

OFICINA DE SOLUÇÕES PROFISSIONAIS

Disciplina: Segurança e Auditoria de Sistemas
Unidade: 2- Política e Cultura de Segurança

Encontro 2 – Resolução de problemas

Neste encontro, você compreenderá os principais conceitos e contextos da disciplina de forma prática, explorando soluções para um problema relacionado ao contexto profissional.

Você deverá concluir a atividade e apresentá-la ao final do encontro.

1. Objetivo da Atividade:

Analisar um cenário organizacional e propor práticas de gestão de acesso a dados, aplicando princípios como classificação da informação, controle de acesso baseado em função (RBAC), autenticação robusta e auditoria de acessos.

2. Descrição da Atividade

A clínica MediCare é uma instituição de saúde de médio porte que atende pacientes particulares e convênios. Seus sistemas informatizados armazenam prontuários médicos, resultados de exames, dados financeiros de pacientes, contratos com convênios e registros administrativos internos. Atualmente, todos os funcionários: médicos, enfermeiros, recepcionistas, técnicos de TI e gestores, utilizam o mesmo login e senha genéricos para acessar o sistema. Não há distinção entre o que cada cargo pode visualizar ou editar. Recentemente, uma recepcionista acessou e imprimiu resultados de exames de um paciente sem nenhuma justificativa clínica, e um técnico de TI alterou inadvertidamente dados financeiros ao realizar uma manutenção. A direção da clínica decidiu contratar uma consultoria para reestruturar a gestão de acesso aos dados antes de uma auditoria de conformidade com a LGPD.

- Classificação dos dados: os dados da organização devem ser categorizados conforme sua sensibilidade (ex.: dados públicos, internos, confidenciais e críticos), pois isso orienta quais controles de acesso serão aplicados a cada tipo de informação.
- Princípio do menor privilégio: cada usuário deve ter acesso apenas às informações estritamente necessárias para o desempenho de suas funções, reduzindo o risco de acessos indevidos, acidentais ou mal-intencionados.
- Controle de acesso baseado em função (RBAC): permissões são associadas a funções organizacionais (ex.: médico, recepcionista, técnico de TI) e cada usuário recebe a

função correspondente ao seu cargo, facilitando o gerenciamento e a revisão de acessos.

- Autenticação robusta e auditoria: mecanismos como senhas individuais fortes e autenticação de dois fatores (2FA) garantem que apenas usuários legítimos acessem o sistema, enquanto logs de auditoria registram quem acessou o quê e quando, permitindo rastrear incidentes.

Com base nesses conceitos, analise o cenário da MediCare e desenvolva uma proposta de gestão de acesso considerando os seguintes elementos:

- Classificação dos dados da clínica: identifique os tipos de dados presentes e classifique-os conforme sua sensibilidade.
- Definição de funções e permissões (RBAC): proponha as funções que devem existir no sistema e descreva quais dados cada função pode acessar, editar ou apenas visualizar.
- Mecanismo de autenticação: indique qual(is) mecanismo(s) de autenticação devem ser adotados e justifique a escolha com base nos dados que serão protegidos.
- Auditoria de acessos: descreva como os registros de acesso devem ser implementados e de que forma eles ajudariam a identificar os dois incidentes descritos no cenário.

Organize sua resposta de forma estruturada, abordando cada um dos quatro elementos acima para a realidade da MediCare.

3. Etapas para Realização

Leia o cenário da MediCare e liste todos os tipos de dados mencionados, classificando cada um como: Público, Interno, Confidencial ou Crítico;

Identifique os cargos presentes na clínica e, aplicando o modelo RBAC e o princípio do menor privilégio, defina quais permissões (visualizar, editar, sem acesso) cada função deve ter sobre cada categoria de dado;

Indique o mecanismo de autenticação mais adequado para a clínica, justificando com base na sensibilidade dos dados armazenados;

Explique como um sistema de auditoria de acessos teria permitido identificar os dois incidentes descritos no cenário antes que causassem maiores danos.